

HIPAA Privacy and Protected Health Information

Policy Number	POL-HIM-080	Owner / Department	Compliance / Health Information Management
Effective Date	2023-04-01	Version	3.1
Last Revised	2026-03-12	Next Review	2028-03-12
Approved By	Compliance & Privacy Committee	Applies To	All workforce members, licensed providers, students, volunteers, and business associates with access to protected health information

1. Purpose

This policy establishes how Riverside Regional Medical Center protects the privacy of protected health information (PHI) and limits its use and disclosure, consistent with the HIPAA Privacy Rule (45 CFR Part 164 Subpart E). It defines permitted uses, the minimum-necessary standard, individual rights, and the duty to report suspected privacy violations.

2. Definitions

- **Protected health information (PHI)** — individually identifiable health information held or transmitted in any form (electronic, paper, or oral).
- **Treatment, payment, and health care operations (TPO)** — the core activities for which PHI may be used or disclosed without a separate authorization.
- **Minimum necessary** — the requirement to limit PHI to the least amount needed to accomplish the intended purpose; does not apply to disclosures to the provider for treatment.
- **Authorization** — a signed, HIPAA-compliant permission required for uses and disclosures not otherwise permitted (e.g., most marketing, sale of PHI, psychotherapy notes).

3. Policy — Permitted Uses and Disclosures

PHI may be used or disclosed for treatment, payment, and health care operations without individual authorization. All other uses and disclosures require a valid authorization unless specifically permitted or required by law (for example, public-health reporting, abuse reporting, or a valid court order). Workforce members access only the PHI required for their role.

- Apply the minimum-necessary standard to every use, disclosure, and request except treatment.
- Verify the identity and authority of any person requesting PHI before disclosing.
- Never access your own record, a family member's record, or a co-worker's record through treatment systems; use the formal records-request process.
- Route media, law-enforcement, and attorney requests to the Privacy Office before responding.

4. Individual Rights

Right	What the patient may do	Owner
Access / copy	Inspect and obtain a copy of their designated record set	HIM
Amendment	Request correction of inaccurate or incomplete PHI	HIM
Accounting of disclosures	Request a list of certain disclosures	Privacy Office
Restriction / confidential communication	Request limits or alternative contact methods	Privacy Office

Requests are logged and acted on within the timeframes in the Notice of Privacy Practices. Denials must cite a permitted ground and inform the individual of review rights.

5. Safeguards

- Position screens away from public view; lock workstations when unattended; never share login credentials.
- Discuss PHI only where it cannot be overheard; avoid patient identifiers in hallways and elevators.
- Encrypt PHI in transit and at rest; do not store PHI on unencrypted or personal devices.
- Shred paper PHI in designated bins; do not place PHI in regular trash or recycling.

IMPORTANT — If you suspect any unauthorized access, use, or disclosure of PHI, report it to the Privacy Office immediately and no later than the end of your shift. Do not attempt to investigate, delete, or “undo” the disclosure yourself — preserve the record and escalate. A potential breach affecting 500 or more individuals is a SEV-1 compliance event.

6. Severity & Reporting

Privacy events are classified on the facility-wide severity scale defined in POL-RM-013 (SEV-1 catastrophic / sentinel, SEV-2 major, SEV-3 minor, Near Miss) and are co-managed with the Privacy Office under POL-HIM-081 (Breach Notification).

Severity	Example privacy event	Notify	By when
SEV-1	Breach of 500+ individuals; large-scale PHI loss/theft	Privacy Officer & Compliance (immediately)	Within 1 hour
SEV-2	Misdirected records; snooping in a record	Privacy Office, manager	Within 4 hours
SEV-3 / Near Miss	Single mis-faxed page intercepted; verbal overshare	Privacy Office via event report	Within 24 hours

7. References

- HIPAA Privacy Rule, 45 CFR Part 164 Subpart E.
- HIPAA Security Rule, 45 CFR Part 164 Subpart C (electronic PHI safeguards).
- Related: POL-HIM-081 (Breach Notification), POL-RM-013 (severity & reporting).